Verdict Runtime

BENCHMARK
2026-11-04
10 apps · 5 languages

We find more labelled flaws than a leading commercial SAST tool and GitHub CodeQL

Head-to-head on ten deliberately vulnerable open-source applications, scored against each app's own labels, plus a live layer that *proves* findings.

On **10 deliberately vulnerable open-source applications across 5 languages**, Verdict Runtime found **92 of 167** labelled, statically findable flaws. **A leading commercial SAST tool found 72** and **GitHub CodeQL found 68**. On an industry-standard Python benchmark it scored **58.5** to the commercial tool's **27.5**.

92/167
Flaws found — Verdict Runtime

72
Commercial SAST tool · +20 for us

68
GitHub CodeQL · +24 for us

58.5
Python benchmark score (commercial SAST tool 27.5)

Round 1: code scanning, like for like

A flaw counts as found only when the correct vulnerability class is reported within ±3 lines of the labelled location, scored against an answer key built from each app's own labels.

SCANNER	LABELLED FLAWS	FOUND	SHARE
Verdict Runtime	167	**92**	**55%**
Commercial SAST tool	167	72	43%
GitHub CodeQL	167	68	41%

Round 1b: OWASP-style Python benchmark, 1,230 cases

63% of the cases are safe code made to look vulnerable. Score = share of real flaws found minus share of safe cases flagged (100 is perfect, 0 is chance); a hit counts only if it names the right weakness type (CWE).

CLASS	US	COMMERCIAL SAST TOOL
SQL injection	0	0
Weak hashing	100	100
Insecure cookie	100	100
Weak randomness	**74.7**	0
Insecure deserialization	**66.7**	55.6
Open redirect	**54.9**	40.7

CLASS	US	COMMERCIAL SAST TOOL
Cross-site scripting	**43.0**	18.0
XPath injection	**40.2**	23.2
Trust boundary	**39.2**	0
Path traversal	**37.1**	−3.2
Command injection	0	**16.5**
Code injection	0	**13.6**
XML external entities	0	0

CLASS	US	COMMERCIAL SAST TOOL
LDAP injection	**43.8**	0

CLASS	US	COMMERCIAL SAST TOOL
Overall	**58.5**	**27.5**

8 classes won, 4 tied, 2 lost. 74% of real flaws found vs 38%, with more safe cases flagged (15.2% vs 10.3%).

The layer the static scanners don’t have LIVE PROOF

9 additional vulnerabilities confirmed by actually exploiting three of the running apps

Verdict Runtime doesn’t just read code: its agents send real, scope-authorised requests and **prove** each finding against the live application, with a reproducing request each:

- **Broken object authorisation (BOLA/IDOR)** — one account read another account’s private data
- **Authentication-token forgery** — an unsigned (`alg:none`) token accepted as valid
- **Exposed admin / debug surfaces** — internal config and server logs served to an unauthenticated request
- **Missing login rate-limiting & weak session cookies**

Static scanners, the commercial tool and CodeQL included, cannot prove any of these. Broken authorisation and token forgery are logic flaws that only show up when you exercise the live application.

The team

Verdict Runtime is built by defenders with more than 15 years in security: protecting applications and infrastructure, running vulnerability programmes at enterprise scale, and building security products that teams rely on. We have a proven record of finding real risk and getting it fixed, and we built the tool we wished we had.

15+
years in security, across defense, vulnerability management and product

Defense
securing applications and infrastructure in production, so every fix and defense rule is built to be deployed

Scale
enterprise vulnerability management: triage, prioritisation and remediation across large estates

Product
security products designed, shipped and run in production

Method & scope. Ten deliberately vulnerable open-source training applications in five languages (JavaScript/TypeScript, Python, Java, Go, C#), each scored against an answer key built from the app’s own labels; a detection counts only when the correct vulnerability class is reported within ±3 lines. Each competing scanner ran at its documented security settings (the commercial tool's default security rules; CodeQL security-extended suites); Verdict Runtime ran its standard code, secrets and infrastructure-as-code scan. The Python benchmark is synthetic and an early release; one run per tool (Verdict Runtime 2026-11-04, commercial SAST tool 2026-10-23). The live-proof results come from Verdict Runtime’s agents against disposable, explicitly authorised local instances. These are labelled training targets, so the results show a measured lead on this suite, not a claim of universal superiority. CodeQL is a trademark of GitHub, Inc.